Análise de arquivo suspeito

Share

codigo.c

C

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Verificando se o arquivo está disponível para leitura

Vou começar lendo as instruções de leitura de arquivos e, em seguida, abrir o arquivo.

Read 2 files, ran a command

Li o arquivo inteiro. A análise é estática: não compilei nem executei nada. **Resposta curta: é malware.** O raciocínio está abaixo.

**1. Identificação**
`codigo.c` é um código-fonte em C de cerca de 36 KB e 927 linhas, para Linux/Unix. Por ser código-fonte, não roda sozinho, mas é um programa completo que, depois de compilado, vira um agente funcional.

**2. Configuração embutida (linhas 1–13)**
No topo há quatro servidores IRC fixos, um canal (`#whatever`), uma senha de canal (`bleh`) e um nome falso de processo (`-bash`). É a configuração típica de um cliente de botnet: onde se conectar, onde esperar ordens e como se disfarçar.

**3. Ocultação (linhas 77–95 e 855–859)**
O programa vai para segundo plano, troca o nome do processo para `-bash` e apaga os argumentos de linha de comando. Assim, parece um shell comum numa listagem de processos. As identidades no IRC (nick, ident, nome) são geradas aleatoriamente a partir de palavras de dicionário ou letras aleatórias.

**4. Comando e controle via IRC (linhas 651–720, 780–818 e 880–925)**
O bot sorteia um servidor da lista, conecta na porta 6667, entra no canal com a senha e espera mensagens iniciadas por `!`. Se a conexão cai, tenta de novo indefinidamente. Não há autenticação do remetente: qualquer pessoa no canal pode dar ordens. Um comando permite migrar o bot para outro servidor.

**5. O que ele executa quando recebe ordens**

- **Shell remoto:** roda comandos arbitrários na máquina e devolve a saída pelo IRC (`SH`, linhas 669–684). Também repassa comandos IRC crus.
- **Download de arquivos:** baixa arquivos da web e grava em disco (`GET`, linhas 152–212), o que permite instalar outros programas.

- **Ataques DDoS:** quatro tipos de inundação (UDP, SYN, TCP ACK/PSH e UDP sem spoofing), em geral com IP de origem forjado e faixa configurável (linhas 268–291 e 347–583). O menu de ajuda (linhas 593–617) descreve essas funções como armas, dizendo que "derrubam a maioria dos drivers de rede" e "não são bloqueadas pela maioria dos firewalls".
- **Gerenciamento:** ativar/desativar com senha, encerrar ataques ou o próprio cliente, trocar de nick e responder à versão com `Kaiten wa goraku` (linha 219).

### 6. Persistência e identd (linhas 1–2, 96–128 e 823–854)

O código sabe se registrar em `/etc/rc.d/rc.local` ou `/etc/rc.conf` para sobreviver a reinicializações. Também sabe responder consultas identd na porta 113. As duas opções estão desativadas por `#undef` nas primeiras linhas, então não entrariam no binário nesta versão, mas o código está lá. A configuração genérica ( `#whatever` , `bleh` ) sugere uma cópia não personalizada, o que não muda a classificação.

### 7. Indicadores úteis para detecção

- **Strings:** `Kaiten wa goraku` , `#whatever` , `bleh` .
- **Processo:** nome `-bash` sem terminal associado.
- **Rede:** conexões de saída na porta TCP 6667 para `irc.qeast.net` , `irc2.magic.ca` , `irc.east.gblx.net` e `irc.west.gblx.net` . São hosts IRC, então conectar a eles não prova infecção por si só, e não verifiquei se ainda existem. Outros sinais são tráfego com IPs de origem forjados e, se compilado com IDENT, escuta na porta 113.
- **Sistema:** linhas extras em `rc.local` / `rc.conf` , se compilado com STARTUP.

### 8. Veredito

Considerei se poderia ser um bot de IRC legítimo, uma ferramenta de teste de estresse ou de administração remota, e a hipótese não se sustenta. Ferramentas legítimas não disfarçam o nome do processo, não apagam argumentos e não aceitam ordens de qualquer participante de um canal. Também não combinam shell remoto, download de arquivos e ataques com IP forjado.

**Conclusão: é malware, com alta confiança.** É o código-fonte de um bot de botnet IRC (backdoor + DDoS) que corresponde à família **Kaiten**, também chamada Tsunami, um código antigo e muito documentado. Isso descreve a natureza do código, não a intenção de quem o guarda. Se for material de estudo ou pesquisa, mantenha-o isolado e não o compile nem execute fora de um ambiente controlado. Se você o encontrou num servidor seu, trate como incidente: isole a máquina, preserve evidências, procure o binário compilado e processos suspeitos, troque credenciais e reinstale a partir de uma base confiável.

Se quiser, posso ajudar a transformar esses indicadores em regras de detecção para a sua equipe de segurança.

Qual é a categoria principal deste malware?

Classificando a família do malware pelo comportamento ▸

A categoria principal é **bot de botnet, mais especificamente um agente de DDoS controlado por IRC**. Essa é a função central do código: transformar a máquina infectada em um "zumbi" que recebe ordens remotas de um canal IRC e participa de ataques de negação de serviço.

Ele também tem duas capacidades secundárias. A primeira é a de **backdoor**, porque executa comandos de shell arbitrários e devolve a saída pelo IRC. A segunda é a de **downloader**, porque baixa arquivos da web e grava em disco.

Ele não se encaixa em outras categorias comuns. Não é worm, porque não há código de varredura ou exploração para se espalhar sozinho. Não é vírus, porque não infecta outros arquivos. Também não é ransomware, spyware ou stealer, já que não criptografa nem coleta dados. E não é rootkit, pois só disfarça o nome do processo como `-bash`, sem esconder arquivos ou módulos do sistema.

Dependendo do fornecedor de antivírus, o rótulo pode variar entre backdoor, trojan ou DDoS bot, geralmente associado às famílias Kaiten ou Tsunami. O comportamento por trás desses rótulos é o descrito acima.